SAVEETHA
INSTITUTE OF MEDICAL AND TECHNICAL SCIENCES
(Declared as Deemed to be University under Section 3 of UGC Act 1956)

COMPUTER SCIENCE AND ENGINEERING

Nov – 2026

ASSIGNMENT – 2

Course Code : **CSA63**

Course Name : **THREAT INTELLIGENCE AND NETWORK SECURITY**

1	A small software company has an office network of about fifty users, a web server and a mail server that must be reachable from the Internet, an internal file server, and an administrator who manages the servers over SSH. The company has one Internet connection and wants to place a firewall at the edge. Apply the concepts of firewalls to this network. Explain the types of firewalls (stateless packet filtering, stateful inspection, application-level gateway or proxy, next-generation firewall and web application firewall) with their strengths and limits, and the role of a DMZ and of network address translation. Prepare an ordered firewall rule table of at least eight rules (action, source, destination, protocol and port, direction and reason) that allows only the required traffic, applies ingress and egress filtering and ends with a default-deny rule. Explain why the order of rules matters, and describe how the rules are tested, logged and reviewed.	(10)	(CO4)	(BL3)
2	The SOC of a university receives about two thousand alerts a day from its intrusion detection system, and analysts estimate that more than ninety per cent are false positives, so a real intrusion in the student hostel network has gone unnoticed for two weeks. Analyse the situation using the concepts of IDS and IPS. Compare network-based and host-based systems, signature-based, anomaly-based and hybrid detection, and passive IDS (SPAN port or network tap) with inline IPS, and explain where sensors should be placed. Explain false positives and false negatives with examples and the cost of each. Interpret this Snort-style rule and say what it detects and how it could be tuned: alert tcp any any -> $HOME_NET 22 (msg:"SSH brute force"; flags:S; threshold:type both, track by_src, count 5, seconds 60; sid:1000001; rev:1;). Recommend a tuning and response process, and discuss how attackers try to evade detection (for example, fragmentation, encryption and slow scans).	(10)	(CO4)	(BL4)
3	A retail company has a head office, ten branch stores and about two hundred staff who sometimes work from home. Branch stores send sales data to the head office, and remote staff need access to the internal inventory system. Apply VPN and secure communication techniques to this requirement. Explain site-to-site and remote-access VPNs, the working of IPsec (AH and ESP, transport and tunnel mode, security associations and IKE) and of SSL/TLS VPNs, and the difference	(10)	(CO4)	(BL3)

	between split tunnelling and full tunnelling. Draw a labelled diagram showing which VPN type is used for the branch stores and which for the remote staff, and justify the choice. Explain the role of TLS and SSH for secure communication of applications and administration, and discuss the security and operational issues of the design, such as multi-factor authentication, key and certificate management, logging, performance and the risk of a compromised home device.			
4	A manufacturing company runs its office computers, ERP servers, guest Wi-Fi, IP cameras and the production-line control systems on one flat network. Last month a ransomware infection on an office laptop spread to the ERP servers and stopped the production line for two days. Analyse how network segmentation and secure architecture design could have limited the damage. Explain VLANs, subnets, internal firewalls and access control lists, a DMZ and micro-segmentation, and design a zone-based architecture with at least five zones (for example, office, servers, DMZ, guest, camera and production) with a table of the traffic that is allowed between zones and the reason for each. Explain how administrators should reach the production zone (for example, through a jump host with multi-factor authentication). Discuss the principles of secure architecture design (least privilege, simplicity, fail-safe defaults, redundancy and separation of duties) and the costs and limits of segmentation.	(10)	(CO4)	(BL4)
5	A financial services firm has moved most of its applications to the cloud and about half of its staff work remotely. A recent breach began with stolen VPN credentials, after which the attacker moved freely across the internal network because the firm trusted everything inside its perimeter. Evaluate the use of the Zero Trust model and the defense-in-depth strategy for this firm. Explain the principles of Zero Trust (never trust and always verify, least privilege, assume breach) and its components (identity provider, multi-factor authentication, device posture checks, policy decision and enforcement points, micro-segmentation and continuous monitoring). Explain the layers of defense in depth (physical, perimeter, network, host, application, data, people and policy) and map one control to each layer for this firm. Evaluate Zero Trust against the traditional perimeter model, explain how the two approaches complement each other, and recommend a phased roadmap with the difficulties the firm is likely to meet, such as legacy systems, user resistance and cost.	(10)	(CO4)	(BL5)

ANSWERS

1. Application of Firewalls to a Small Software Company

Introduction

A firewall is a network security device that monitors and controls incoming and outgoing network traffic based on security rules. It protects the company network from unauthorized access and cyberattacks.

The company has:

- Around 50 office users.
- A web server accessible from the Internet.
- A mail server accessible from the Internet.
- An internal file server.
- An administrator who manages servers using SSH.

Types of Firewalls

Firewall type	Explanation	Strength	Limitation
Stateless packet filtering	Checks IP addresses, ports and protocols.	Fast and simple.	Does not track connections.
Stateful inspection	Tracks active network connections.	Better security than stateless filtering.	Uses more resources.
Application-level gateway (Proxy)	Checks application traffic such as HTTP and FTP.	Provides detailed application control.	Can slow down communication.
Next-generation firewall (NGFW)	Provides firewall protection, intrusion prevention and application control.	Detects advanced threats.	Expensive and complex.
Web application firewall (WAF)	Protects web applications from attacks such as SQL injection and cross-site scripting.	Protects web applications.	Does not protect all network traffic.

Role of DMZ

DMZ stands for Demilitarized Zone. It is a separate network area used to place public-facing servers.

- The web server and mail server are placed in the DMZ.
- Internet users can access these servers.
- The internal file server is kept inside the private network.
- Direct Internet access to the internal network is blocked.

This reduces the risk of attackers reaching internal systems.

Role of NAT

NAT stands for Network Address Translation.

- It converts private IP addresses into public IP addresses.
- It allows multiple office computers to share one public IP address.
- It hides internal IP addresses from external networks.
- Port forwarding can be used to direct approved Internet traffic to the web and mail servers.

Ordered Firewall Rule Table

The following is an example of firewall rules for the company.

No.	Action	Source	Destination	Protocol/Port	Direction	Reason
1	Allow	Internet	Web server	TCP 443	Incoming	Allows secure website access.
2	Allow	Internet	Mail server	TCP 25	Incoming	Allows incoming email.
3	Allow	Internet	Mail server	TCP 587	Incoming	Allows secure email submission.
4	Allow	Admin IP	Servers	TCP 22	Incoming	Allows SSH administration.
5	Allow	Office network	Internet	TCP 80, 443	Outgoing	Allows web browsing.
6	Allow	Office network	Mail server	Required mail ports	Internal	Allows employees to use email.
7	Allow	Office network	File server	Required file-sharing ports	Internal	Allows employees to access files.
8	Allow	Internal network	DNS server	UDP/TCP 53	Outgoing	Allows domain name resolution.

9	Deny	Internet	Internal network	All other traffic	Incoming	Blocks unauthorized access.
10	Deny	Any	Any	All other traffic	Both	Default-deny rule.

Note: The exact mail and file-sharing ports depend on the services used by the company.

Importance of Rule Order

- Firewall rules are checked from top to bottom.
- The first matching rule is applied.
- Specific allow rules must come before general deny rules.
- If a deny rule comes first, valid traffic may also be blocked.
- The final rule blocks all traffic that is not specifically allowed.

Testing, Logging and Reviewing

1. Test whether the website and mail server are accessible.
2. Check whether employees can access the file server.
3. Verify that SSH is accessible only from the administrator's approved IP address.
4. Check that unauthorized traffic is blocked.
5. Enable firewall logs to record allowed and blocked connections.
6. Review logs regularly to identify suspicious activities.
7. Update firewall rules when company requirements change.

Conclusion

A properly configured firewall protects the company network from unauthorized access. Using a DMZ, NAT, ingress filtering, egress filtering and default-deny rules improves network security.

2. Analysis of IDS and IPS in a University Network

Introduction

An Intrusion Detection System (IDS) monitors network or system activities and identifies suspicious behaviour.

An Intrusion Prevention System (IPS) detects suspicious activities and can automatically block them.

In the given university, the SOC receives around 2,000 alerts daily, and more than 90% are false positives. Due to this, a real attack in the student hostel network remained unnoticed for two weeks.

Difference Between IDS and IPS

IDS	**IPS**
Detects suspicious activities.	Detects and blocks suspicious activities.
Usually works passively.	Usually works inline.
Sends alerts to administrators.	Can automatically stop attacks.
Does not normally block traffic.	Can block malicious traffic.

Types of IDS and IPS

1. Network-Based IDS (NIDS)
   - Monitors network traffic.
   - Installed at important network points.
   - Detects suspicious communication between devices.
   - Example: Detecting unusual traffic from the student hostel network.
2. Host-Based IDS (HIDS)
   - Installed on individual computers and servers.
   - Monitors system files, logs and processes.
   - Detects unauthorized changes to files.
3. Signature-Based Detection
   - Identifies attacks using known attack patterns.
   - Works well against previously identified threats.
   - May fail to detect new attacks.

4. Anomaly-Based Detection

- Learns normal network behaviour.
- Identifies unusual activities.
- Can detect unknown attacks.
- May generate more false positives.

5. Hybrid Detection

- Combines signature-based and anomaly-based detection.
- Provides better attack detection.
- Can identify both known and unusual attacks.

Passive IDS and Inline IPS

Passive IDS	**Inline IPS**
Connected through a SPAN port or network tap.	Placed directly in the traffic path.
Monitors and generates alerts.	Monitors and blocks attacks.
Does not directly interrupt traffic.	Can stop malicious traffic.
Suitable for monitoring.	Suitable for prevention.

Recommended Sensor Placement

- At the Internet gateway to monitor external traffic.
- Between the server network and office network.
- In the student hostel network.
- Near important databases and university servers.
- On important individual servers using host-based IDS.

False Positives and False Negatives

False Positive: A normal activity is incorrectly identified as an attack.

Example: A student downloading a large file is identified as suspicious activity.

Cost: Wastes the SOC team's time and may cause important alerts to be ignored.

False Negative: A real attack is not detected.

Example: An attacker accesses a university server, but the IDS does not generate an alert.

Cost: Attackers may steal data, damage systems or remain inside the network for a long time.

Interpretation of the Snort Rule

Given rule:

alert tcp any any -> $HOME_NET 22

(msg:"SSH brute force";

flags:S;

threshold:type both, track by_src, count 5, seconds 60;

sid:1000001;

rev:1;)

Explanation:

Rule part	**Meaning**
alert	Generates an alert.
tcp	Monitors TCP traffic.
any any	Accepts any source IP and source port.
$HOME_NET	Represents the protected network.
22	SSH port.
msg	Displays the message "SSH brute force".
flags:S	Checks TCP SYN packets.
threshold	Controls alert frequency.
track by_src	Tracks traffic based on source IP.
count 5	Uses a threshold of five matching packets.
seconds 60	Uses a 60-second time period.
sid	Unique rule identification number.
rev	Rule revision number.

This rule looks for repeated TCP SYN packets directed towards SSH port 22 from the same source within 60 seconds. It is intended to

identify possible SSH brute-force activity, but SYN packets alone do not prove that login attempts have occurred.

Tuning and Response Process

1. Identify normal network behaviour.
2. Analyse repeated alerts.
3. Adjust thresholds to reduce false positives.
4. Whitelist trusted systems where appropriate.
5. Correlate alerts with server authentication logs.
6. Prioritise high-risk alerts.
7. Investigate suspicious source IP addresses.
8. Block confirmed malicious traffic.
9. Update detection rules regularly.

How Attackers Evade Detection

- Fragmentation: Attackers divide packets into smaller parts to avoid detection.
- Encryption: Encrypted traffic makes inspection difficult.
- Slow scans: Attackers scan slowly to avoid triggering detection thresholds.

Conclusion

IDS and IPS are important security tools for universities. Proper sensor placement, alert tuning and continuous monitoring help reduce false alerts and detect real attacks quickly.

3. VPN and Secure Communication for a Retail Company

Introduction

A Virtual Private Network (VPN) creates a secure connection over the Internet. It protects data from unauthorized access by using encryption and authentication.

The retail company has one head office, ten branch stores and around 200 employees. Branch stores send sales data to the head office, and remote employees need access to the internal inventory system.

Types of VPN

1. Site-to-Site VPN

- Connects two or more office networks through the Internet.
- Uses VPN devices or routers at both locations.
- Automatically protects communication between branch stores and head office.
- Suitable for connecting all ten branch stores.

2. Remote-Access VPN

- Allows individual employees to connect securely to the company network.
- Employees use VPN software on their laptops or computers.
- Requires authentication before access is granted.
- Suitable for employees working from home.

Working of IPsec

IPsec stands for Internet Protocol Security. It protects IP communication using authentication and encryption.

Main components of IPsec:

1. Authentication Header (AH)

- Provides data authentication and integrity.
- Helps verify that data has not been modified.
- Does not provide encryption.

2. Encapsulating Security Payload (ESP)

- Provides data encryption.
- Can also provide authentication and integrity.
- Protects data from unauthorized reading.

3. Transport Mode

- Protects the data portion of an IP packet.
- The original IP header remains visible.
- Commonly used for communication between two systems.

4. Tunnel Mode

- Protects the complete original IP packet.
- Adds a new IP header.
- Commonly used in site-to-site VPN connections.

5. Security Association (SA)

- Defines the security settings for a connection.
- Contains information such as encryption algorithms and keys.

6. Internet Key Exchange (IKE)

- Establishes secure communication between VPN devices.
- Negotiates security settings.
- Helps create and manage encryption keys.

SSL/TLS VPN

SSL/TLS VPN uses TLS encryption to provide secure remote access through a web browser or VPN client.

- Protects communication between employees and company systems.
- Provides encrypted access to internal applications.
- Can support remote employees without requiring a complete network connection.

Split Tunnelling and Full Tunnelling

Split tunnelling	**Full tunnelling**
Only company-related traffic passes through the VPN.	All Internet traffic passes through the VPN.
Reduces VPN bandwidth usage.	Provides more centralized security monitoring.
Personal Internet traffic uses the normal Internet connection.	Personal and company traffic both use the VPN.
May increase security risks if personal traffic is unsafe.	Can increase network load and slow down Internet access.

Recommended VPN Design

Requirement Recommended VPN Reason

Ten branch stores	Site-to-site IPsec VPN	Provides secure and continuous communication between branches and head office.
Remote employees	Remote-access SSL/TLS VPN or IPsec VPN	Allows employees to securely access the inventory system from home.

Role of TLS and SSH

TLS (Transport Layer Security)

- Protects communication between applications and servers.
- Encrypts website and application traffic.
- Helps prevent data theft during communication.

SSH (Secure Shell)

- Provides secure remote administration of servers.
- Encrypts administrator communication.
- Protects server login credentials.
- Commonly uses TCP port 22.

Security and Operational Issues

1. Multi-Factor Authentication (MFA): Requires an additional verification method apart from a password.
2. Key Management: Encryption keys must be stored and updated securely.
3. Certificate Management: Digital certificates must be valid and renewed before expiry.
4. Logging: VPN login attempts and user activities should be recorded.
5. Performance: Encryption may increase processing requirements and network delays.
6. Compromised Home Devices: Infected personal devices may introduce malware into the company network.

Conclusion

Using site-to-site VPNs for branch stores and remote-access VPNs for employees provides secure communication. IPsec, TLS, SSH and multi-factor authentication help protect company information.

4. Network Segmentation and Secure Architecture Design

Introduction

Network segmentation is the process of dividing a large network into smaller separate networks called segments.

In the given manufacturing company, office computers, ERP servers, guest Wi-Fi, IP cameras and production systems are connected to one flat network. Because of this, ransomware spread from an office laptop to ERP servers and production systems.

Network segmentation can reduce this damage by separating important systems.

Important Concepts

1. VLAN (Virtual Local Area Network)
   - Divides a physical network into separate logical networks.
   - Devices in different VLANs are separated.
   - Improves security and network management.
2. Subnet
   - Divides an IP network into smaller address ranges.
   - Helps organize devices based on their functions.
   - Makes network traffic management easier.
3. Internal Firewall
   - Controls communication between internal network segments.
   - Blocks unauthorized connections.
   - Allows only approved traffic.
4. Access Control List (ACL)
   - Contains rules that allow or deny network traffic.
   - Controls access based on IP addresses, protocols and ports.
5. DMZ (Demilitarized Zone)

- A separate network used for public-facing servers.
- Protects the internal network from direct Internet access.
- Limits the risk of external attacks reaching internal systems.

6. Micro-Segmentation

- Divides the network into smaller security zones.
- Controls communication between individual workloads or systems.
- Reduces the spread of malware and ransomware.

Zone-Based Network Architecture

The company should divide its network into the following six zones.

Zone	**Purpose**
Office Zone	Employee computers and office devices.
Server Zone	ERP servers and internal business applications.
DMZ Zone	Public-facing servers.
Guest Zone	Visitors' Wi-Fi devices.
Camera Zone	IP cameras and monitoring devices.
Production Zone	Production-line control systems and industrial devices.

Traffic Allowed Between Zones

Source Zone	**Destination Zone**	**Allowed Traffic**	**Reason**
Office	Server	Approved ERP application traffic	Allows employees to use ERP.
Office	DMZ	Approved web traffic	Allows access to public-facing services.
Guest	Internet	HTTP/HTTPS	Allows visitors to browse the Internet.

Guest	Office/Server	Denied	Prevents unauthorized internal access.
Camera	Monitoring Server	Approved camera traffic	Allows security monitoring.
Production	Approved control server	Required control traffic	Supports production operations.
Server	Production	Only approved required traffic	Allows necessary business communication.
Administrator	Production	Through jump host only	Provides controlled administration.
DMZ	Internal Server	Only specifically required traffic	Reduces the risk of server compromise spreading internally.

All other traffic between zones should be blocked by default.

Secure Administration of Production Zone

Administrators should not connect directly from normal office computers to production systems.

They should use a Jump Host.

- A jump host is a secure computer used to access important systems.
- Administrators must log in using multi-factor authentication.
- Only authorized administrators should have access.
- All administrative activities should be logged.
- Direct access from guest and office networks should be blocked.

Principles of Secure Architecture Design

Principle	**Explanation**
Least Privilege	Users receive only the permissions needed for their work.

Simplicity	The network design should be simple and easy to manage.
Fail-Safe Defaults	Access should be denied unless it is specifically allowed.
Redundancy	Backup devices and network connections help maintain availability.
Separation of Duties	Important tasks should be divided among different people.

Costs and Limitations of Segmentation

- Requires additional firewalls, switches and network equipment.
- Increases installation and maintenance costs.
- Needs skilled network administrators.
- Incorrect firewall rules may block genuine communication.
- Troubleshooting becomes more complex.
- Some old production devices may not support modern security controls.

Conclusion

Network segmentation protects manufacturing systems by separating office, server, guest, camera and production networks. Firewalls, VLANs, ACLs and jump hosts help prevent ransomware from spreading across the entire company.

5. Zero Trust Model and Defense-in-Depth Strategy

Introduction

Zero Trust is a security model based on the principle "Never Trust, Always Verify."

It means that no user or device should automatically be trusted, even if it is connected to the company network.

In the given financial services firm, attackers stole VPN credentials and moved freely inside the network because the company trusted everything within its perimeter.

Zero Trust and Defense in Depth can help prevent similar attacks.

Principles of Zero Trust

1. Never Trust, Always Verify

- Every user and device must be verified before accessing resources.
- Users must prove their identity.
- Access should not be automatically granted to internal network users.

2. Least Privilege

- Users receive only the permissions required for their work.
- Employees should not have unnecessary access to financial applications.
- Reduces the damage caused by compromised accounts.

3. Assume Breach

- The company should always be prepared for a security breach.
- Suspicious activities must be monitored continuously.
- Network access should be restricted to prevent attackers from moving freely.

Components of Zero Trust

Component	**Explanation**
Identity Provider	Verifies user identities.
Multi-Factor Authentication (MFA)	Uses additional verification apart from passwords.
Device Posture Checks	Checks whether a device is secure and updated.
Policy Decision Point (PDP)	Decides whether access should be allowed or denied.
Policy Enforcement Point (PEP)	Applies the access decision.
Micro-Segmentation	Divides the network into smaller protected sections.
Continuous Monitoring	Continuously checks user and device activities.

Defense-in-Depth Strategy

Defense in Depth is a security strategy that uses multiple layers of protection.

If one security layer fails, other layers help protect the organization.

Layers of Defense in Depth

Layer	Explanation	Security Control for the Firm
Physical Security	Protects physical devices and buildings.	CCTV cameras and biometric access.
Perimeter Security	Protects the company network from external attacks.	Firewall and secure VPN gateway.
Network Security	Protects internal network communication.	Network segmentation and IDS/IPS.
Host Security	Protects computers and servers.	Antivirus and endpoint detection.
Application Security	Protects software and applications.	Secure coding and web application firewall.
Data Security	Protects confidential company information.	Data encryption and access control.
People Security	Educates employees about cyber threats.	Security awareness training.
Policy Security	Defines security rules and procedures.	Password policies and access control policies.

Zero Trust Model vs Traditional Perimeter Model

Zero Trust Model	Traditional Perimeter Model
Never automatically trusts users or devices.	Generally trusts users inside the network perimeter.
Verifies every access request.	Mainly checks access at the network boundary.
Uses continuous monitoring.	Often focuses on external threats.
Provides least-privilege access.	May provide broad internal access.

Suitable for cloud and remote working.	Mainly designed for traditional office networks.
Reduces internal attacker movement.	Attackers may move freely after entering the network.

How Both Approaches Work Together

Zero Trust and Defense in Depth are complementary security approaches.

- Zero Trust verifies every user and device.
- Defense in Depth provides multiple layers of protection.
- Firewalls protect the network perimeter.
- MFA protects user accounts.
- Endpoint security protects computers.
- Micro-segmentation restricts internal access.
- Encryption protects confidential data.
- Continuous monitoring helps detect suspicious activities.

Using both approaches provides stronger security than depending on only one method.

Recommended Phased Implementation Roadmap

Phase 1: Identify and Assess

- Identify important applications, servers and sensitive data.
- Review existing network security.
- Identify vulnerable systems and accounts.

Phase 2: Strengthen Identity Security

- Implement MFA for all employees.
- Use a centralized identity provider.
- Apply least-privilege access.
- Remove unnecessary user permissions.

Phase 3: Secure Devices

- Check device health before granting access.
- Install antivirus and endpoint protection.

- Ensure devices have updated software and security patches.

Phase 4: Implement Network Segmentation

- Divide the network into separate security zones.
- Use internal firewalls and ACLs.
- Restrict access to sensitive financial applications.

Phase 5: Continuous Monitoring

- Monitor user login activities.
- Analyse security logs.
- Detect suspicious access attempts.
- Respond quickly to security incidents.

Difficulties in Implementation

1. Legacy Systems: Older applications may not support modern Zero Trust security.
2. User Resistance: Employees may find MFA and additional verification inconvenient.
3. Cost: New security tools and infrastructure require investment.
4. Complexity: Managing multiple security systems can be difficult.
5. Performance: Continuous verification and encryption may affect system performance.

Conclusion

Zero Trust and Defense in Depth provide strong protection for financial services firms. Zero Trust verifies every user and device, while Defense in Depth provides multiple security layers. Implementing both approaches gradually helps prevent unauthorized access and reduces the impact of cyberattacks.